

JUNIO 2026

THE BRIDGE
BOOTCAMPS

A series of white, wavy, horizontal lines of varying thicknesses that create a sense of movement and depth across the middle of the page.

OWASP TOP 10 2025



Versión	Fecha	Estado	Clasificación
1.0	Junio 2026	Aprobado	Interno

Propósito y alcance

El presente documento analiza las diez categorías de vulnerabilidades más críticas según OWASP Top 10:2025, aplicadas al contexto específico de Aupa!, una aplicación web de recomendaciones turísticas del País Vasco desarrollada como proyecto integrador del bootcamp de ciberseguridad de The Bridge.

Para cada categoría se identifican el agente de amenaza probable, el vector de ataque principal y el impacto potencial sobre la aplicación, considerando su stack tecnológico (Node.js + Express + PostgreSQL en backend, React + Vite en frontend, Python + FastAPI para el módulo de ciencia de datos) y su modelo de autenticación híbrido (OAuth Google + JWT + acceso invitado).

El objetivo es proporcionar una base técnica para la priorización de controles de seguridad durante la fase de desarrollo y despliegue de Aupa!, alineada con las buenas prácticas de la industria y complementaria al análisis MAGERIT y el Threat Model ATT&CK ya realizados.

OBJETIVO

Aplicación Aupa

Backend · Frontend · API DS

ESTÁNDAR

OWASP Top 10:2025

10 categorías de riesgo

METODOLOGÍA

Agente · Vector · Impacto

Contextualizado en Aupa!

STACK ANALIZADO

**Node.js · Express · PostgreSQL ·
React · FastAPI · Docker**

AUTENTICACIÓN

**OAuth (Google) · JWT · Acceso
invitado**



OWASP Top 10 - Aupa!

■ Agente ■ Vector ■ Impacto ■ En aupa!

VULNERABILIDAD	AGENTE	VECTOR	IMPACTO	EN AUPA!
A01 Broken access control CRÍTICO	Usuario autenticado Atacante externo	Manipulación de parámetros IDOR en endpoints	Acceso a datos de otros usuarios IDOR en endpoints	Un usuario invitado podría acceder a rutas protegidas si el middleware JWT no valida correctamente el rol. Endpoints de recomendaciones o perfiles sin verificación de pertenencia.
A02 Security Misconfiguration ALTO	Atacante externo Bot automatizado	Headers HTTP por defecto Variables de entorno expuestas	Fuga de información técnica Escalada de privilegios	Exposición de stack traces en entorno dev, headers sin CSP/HSTS, o .env con credenciales de PostgreSQL accesible en repositorio.
A03 Software Supply Chain Failures ALTO	Proveedor de paquetes Actor de cadena de suministro	Paquetes desactualizados Dependencias npm/pip comprometidas	Ejecución de código malicioso Backdoor en producción	Stack con múltiples dependencias npm (Express, Sequelize, Redux) y pip (FastAPI). SonarQube detecta versiones vulnerables. Controlado parcialmente con SBOM.
A04 Cryptographic Failures ALTO	Atacante en tránsito (MitM) Acceso a BD	Transmisión sin TLS Tokens JWT sin expiración	Robo de credenciales Suplantación de sesión	Si los JWT no tienen expiración corta o el secreto de firma es débil, un token robado permite acceso indefinido. Contraseñas en BD deben usar bcrypt, no MD5/SHA1.
A05 Injection CRÍTICO	Atacante externo Usuario malicioso	SQL Injection vía ORM XSS en inputs de búsqueda	Ejecución de scripts en cliente Volcado de base de datos	Sequelize protege contra SQLi si se usan métodos parametrizados. El buscador de lugares turísticos y los campos de recomendaciones son vectores de XSS si no se sanitizan.

OWASP Top 10 - Aupa!

Agente
Vector
Impacto
En aupa!

VULNERABILIDAD	AGENTE	VECTOR	IMPACTO	EN AUPA!
A06 Insecure Design ALTO	Desarrollador Arquitecto de sistema	Ausencia de controles en diseño Flujos de negocio sin validación	Lógica de negocio comprometida Abuso de funcionalidades	El acceso invitado sin límites puede ser abusado para scraping masivo de recomendaciones. Falta de rate limiting en la API del módulo DS (FastAPI en Render).
A07 Authentication Failures CRÍTICO	Atacante externo Bot de credential stuffing	Robo de token OAuth Fuerza bruta en login por email	Acceso no autorizado a perfil Toma de cuenta	El endpoint de login por email sin límite de intentos es vulnerable a fuerza bruta. El flujo OAuth de Google debe validar el state parameter para evitar CSRF en el callback.
A08 Software or Data Integrity Failures MEDIO	Atacante en cadena CI/CD Insider malicioso	Deserialización insegura Pipeline sin verificación de integridad	Despliegue de código malicioso Manipulación de datos en tránsito	El módulo FastAPI desplegado en Render debe validar los datos recibidos del backend Node.js. Sin verificación de firma entre servicios, un atacante podría inyectar datos en las recomendaciones IA.
A09 Security Logging & Alerting Failures ALTO	Atacante persistente Insider	Ausencia de logs de acceso Alertas no configurada	Ataques no detectados Sin trazabilidad forense	Sin logging de intentos de login fallidos, cambios de rol o accesos a endpoints sensibles, un ataque de baja intensidad pasaría desapercibido. Directamente relacionado con las reglas SIEM del proyecto.
A10 Mishandling of Exceptional Conditions MEDIO	Atacante externo Usuario no previsto	Excepciones en FastAPI sin handler Errores no capturados en Express	Comportamiento impredecible Fuga de stack traces	Un error no manejado en el ORM Sequelize (ej. consulta inválida) puede devolver detalles internos de PostgreSQL al cliente. Middleware de error global obligatorio en Express.

